Title
Lack of Brute Force Protection Allows Account Compromise

Severity
High (7.3 CVSS score)

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Affected endpoint

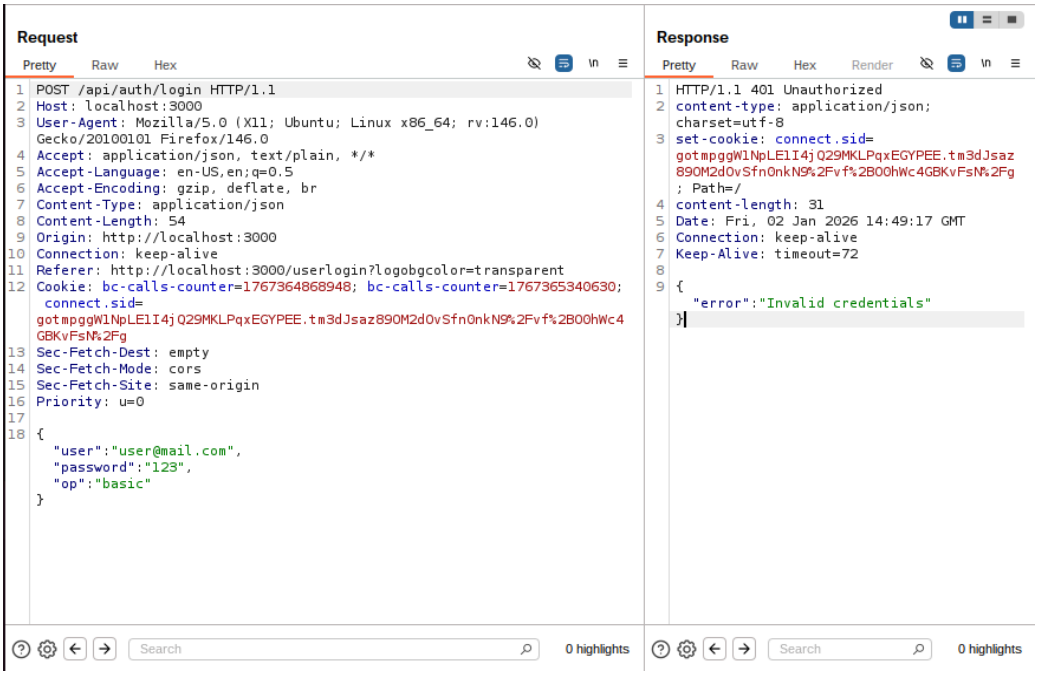
- POST **/userlogin**
- All authentication endpoints without rate limiting or account lockout

Vulnerability description
The application does not implement adequate protection mechanisms against brute force attacks on the authentication functionality. An attacker can repeatedly submit authentication attempts using automated tools without encountering any form of restriction, such as rate limiting, CAPTCHA, or account lockout.

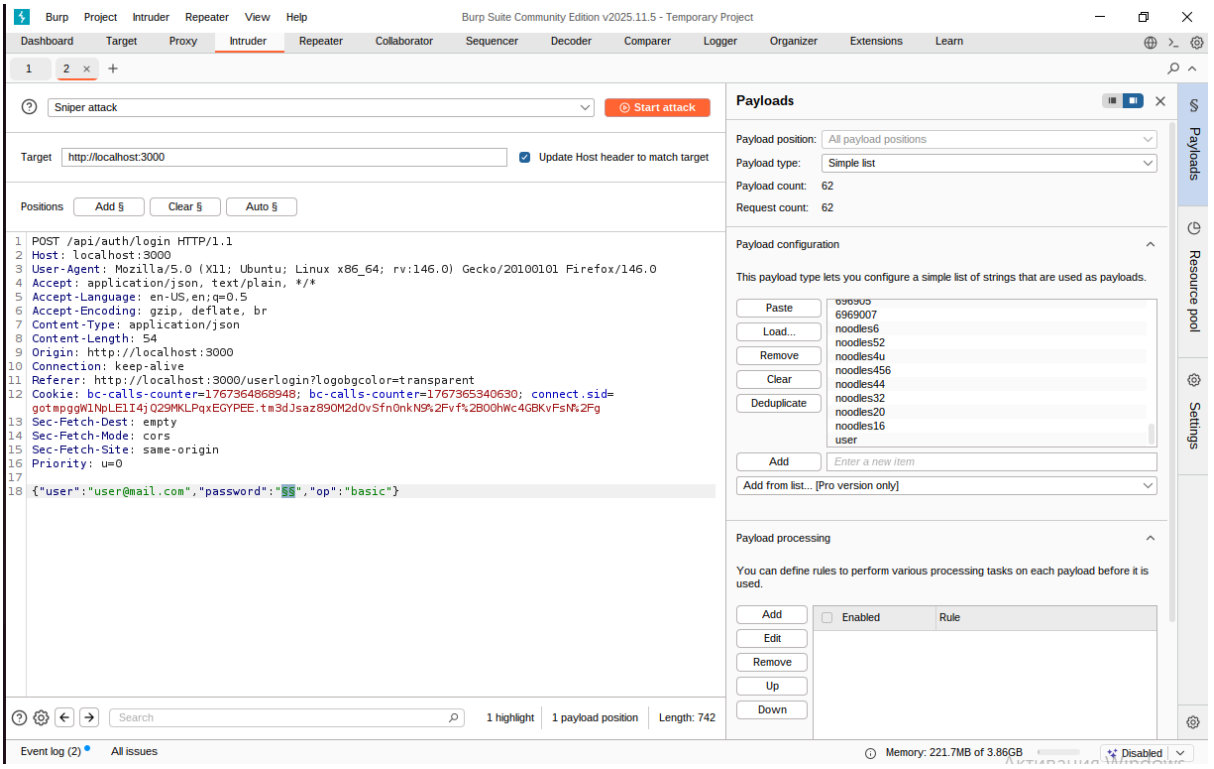
Additionally, the application returns distinguishable HTTP responses based on the correctness of the supplied password. When valid credentials are provided, the server responds with HTTP status code 201, allowing attackers to reliably identify successful authentication attempts and accelerate brute force attacks.

Proof of Concept

1. Log in using an existing user account identifier:
    - Email: user@mail.com
2. Intercept the login request using **Burp Suite Community Edition.**

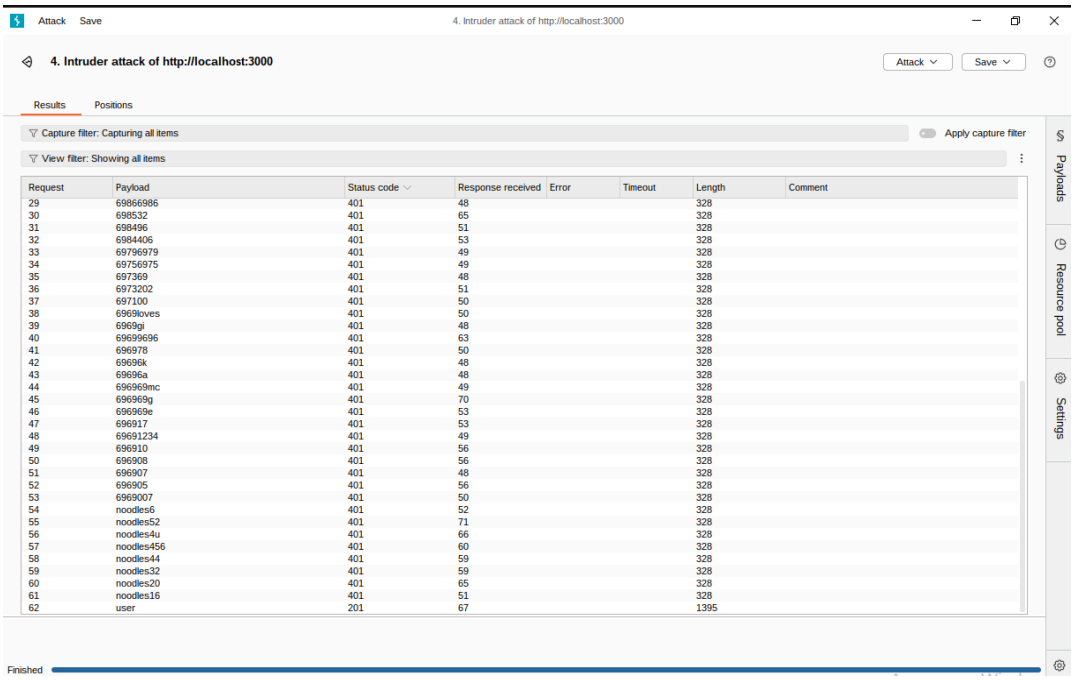


3. Send the request to **Intruder** and configure a brute force attack against the password parameter.



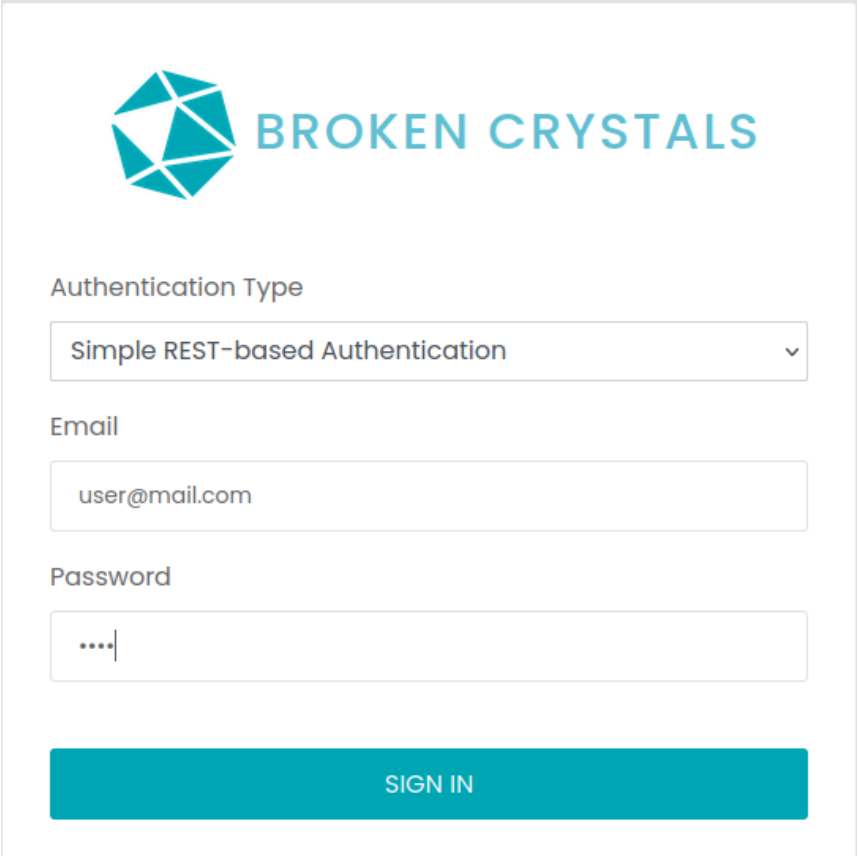
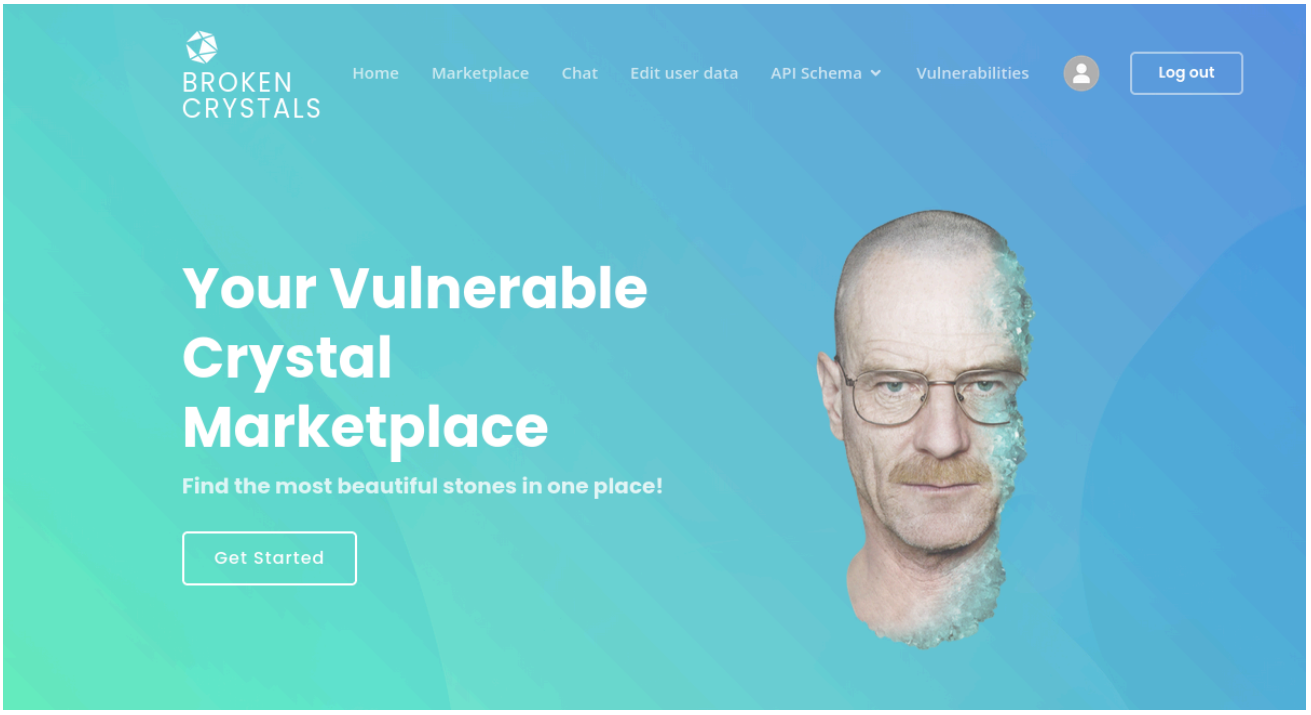
4. Start the attack using a password wordlist.
5. Observe the server responses:
   - Incorrect passwords return a different HTTP status code

- The correct password returns **HTTP 201**, clearly distinguishing successful authentication



Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
29	69866986	401	48			328	
30	698532	401	65			328	
31	698496	401	51			328	
32	6984406	401	53			328	
33	69796979	401	49			328	
34	69756975	401	49			328	
35	697369	401	48			328	
36	6973202	401	51			328	
37	697100	401	50			328	
38	6969loves	401	50			328	
39	6969gi	401	48			328	
40	69699696	401	63			328	
41	696978	401	50			328	
42	69696k	401	48			328	
43	69696a	401	48			328	
44	696969mc	401	49			328	
45	696969g	401	70			328	
46	696969e	401	53			328	
47	696917	401	53			328	
48	69691234	401	49			328	
49	696910	401	56			328	
50	696908	401	56			328	
51	696907	401	48			328	
52	696905	401	56			328	
53	6969007	401	50			328	
54	noodles6	401	52			328	
55	noodles52	401	71			328	
56	noodles4u	401	66			328	
57	noodles456	401	60			328	
58	noodles44	401	59			328	
59	noodles32	401	59			328	
60	noodles20	401	65			328	
61	noodles16	401	51			328	
62	user	201	67			1395	

6. Use the discovered credentials to log in via the application's UI.



7. Successful authentication confirms full account compromise.